

EA-0035 - AQELYN Engineering Archive

EA-0035 - AQELYN Secrets, Keys & Certificate Lifecycle Governance Engine

****Implementation Specification:**** IS-035

****Publication Standard:**** FULL_COMPLETE

****Generated:**** 2026-07-08

001 Document Control

Project: AQELYN

Engineering Archive: EA-0035

Implementation Specification: IS-035

Title: AQELYN Secrets, Keys & Certificate Lifecycle Governance Engine

Publication Standard: FULL_COMPLETE

Document Type: Master Engineering Archive

Source Format: Markdown

Derived Formats: PDF, HTML

Repository Status: Immutable

Classification: Internal Engineering

Archive Series: EA-0001 -> EA-0035

Purpose: This document is the authoritative engineering archive for the AQELYN Secrets, Keys & Certificate Lifecycle Governance Engine. It defines the complete operating model, architecture, canonical objects, event contracts, security model, testing plan, publication assets, and implementation guidance required to build the engine as part of the AQELYN Cyber Security Operating Environment.

Engineering authority hierarchy:

1. Project Charter
2. Engineering Principles
3. Repository Standard
4. Architecture Guide
5. Development Rules
6. Publication Standard
7. This Engineering Archive

Audience: platform architects, security architects, identity engineers, PKI engineers, DevSecOps engineers, software engineers, test engineers, auditors, and release engineers.

002 Revision History

Version: 1.0

Date: Initial publication

Description: First complete engineering specification for EA-0035.

Status: Draft for publication

Engineering change policy: all changes shall be version controlled, traceable, reviewed, and reflected in the Engineering Journal. No requirement, interface, or event contract may be removed without a documented compatibility and migration decision.

003 Executive Summary

Secrets, cryptographic keys, certificates, signing credentials, tokens, and trust anchors form the operational fabric that allows machine identities and services to authenticate, encrypt, sign, validate, and communicate. Weak governance of these materials leads to outages, privilege compromise, impersonation, data exposure, and loss of trust in security controls.

EA-0035 defines the AQELYN Secrets, Keys & Certificate Lifecycle Governance Engine. The engine discovers cryptographic and credential assets, classifies them, evaluates their lifecycle state, detects exposure and drift, integrates with trust and policy engines, publishes lifecycle events, and produces remediation guidance.

The engine does not replace vaults, KMS platforms, HSMS, certificate authorities, or cloud secret managers. Instead, it governs them through standardized connectors and canonical AQELYN objects. It establishes a unified lifecycle governance layer across heterogeneous cryptographic and credential ecosystems.

Expected outcomes include a complete inventory of secrets and certificates, deterministic risk scoring, policy-based rotation governance, exposure detection, certificate expiration prevention, key strength evaluation, evidence-backed findings, and integration with workflow automation for remediation.

004 Vision

The vision of IS-035 is to make every sensitive credential and cryptographic asset visible, governed, lifecycle-aware, policy-controlled, and evidence-backed.

The engine shall enable AQELYN to answer five operational questions at all times:

- What sensitive credentials exist?
- Who or what owns them?
- Where are they stored and used?
- Are they compliant with lifecycle and protection policy?
- What action is required to reduce risk?

The long-term architectural vision is a unified governance plane where secrets, certificates, keys, tokens, signing credentials, and trust anchors are treated as first-class security objects connected to machine identities, applications, workloads, missions, policies, evidence, and risk.

005 Purpose

The engine provides continuous lifecycle governance for secrets, keys, certificates, tokens, and related cryptographic assets. It exists to reduce credential exposure, prevent certificate-related outages, strengthen cryptographic hygiene, and provide auditable evidence for governance and compliance.

Primary purposes:

- Discover sensitive credential assets across providers.
- Normalize provider-specific records into AQELYN canonical objects.
- Evaluate lifecycle, ownership, usage, storage, and protection state.

- Detect expired, stale, weak, reused, exposed, unmanaged, and orphaned credentials.
- Prioritize remediation using mission, trust, evidence, and policy context.
- Publish immutable lifecycle and governance events.

006 Scope

In scope:

- API keys, OAuth client secrets, refresh tokens, personal access tokens, service credentials, SSH keys, TLS certificates, code signing certificates, JWT signing keys, encryption keys, database credentials, cloud access keys, vault secrets, PKI trust anchors, HSM references, workload identity tokens, and automation secrets.
- Providers: HashiCorp Vault, CyberArk, Azure Key Vault, AWS Secrets Manager, AWS KMS, Google Secret Manager, cloud IAM, Kubernetes Secrets, GitHub, GitLab, Jenkins, CI/CD systems, enterprise PKI, Venafi-like certificate platforms, HSM/KMS metadata providers, and file/config scanning connectors.

Out of scope:

- Replacing a vault, KMS, CA, or HSM.
- Directly decrypting or exposing secret values.
- Performing unauthorized credential rotation.
- Storing plaintext secrets in AQELYN repositories.

AQELYN stores metadata, evidence references, hashes/fingerprints where safe, lifecycle state, and governance outputs; it shall not become a plaintext secret repository.

007 Engineering Objectives

OBJ-001 Discover governed credential assets.

OBJ-002 Classify each asset by type, use case, provider, owner, and sensitivity.

OBJ-003 Establish lifecycle state and rotation requirements.

OBJ-004 Detect expiration, weakness, reuse, exposure, orphaning, and governance drift.

OBJ-005 Maintain evidence-backed governance history.

OBJ-006 Integrate with Identity, Machine Identity, Trust, Policy, Workflow, Knowledge Graph, Evidence, Mission, and Compliance engines.

OBJ-007 Generate deterministic risk and governance scores.

OBJ-008 Publish immutable events for lifecycle changes and findings.

OBJ-009 Support enterprise-scale inventories and high-volume evaluation.

OBJ-010 Enable remediation workflows without directly revealing sensitive values.

Engineering KPIs:

- Inventory coverage $\geq$ 99 percent of configured sources.
- Evidence linkage = 100 percent for findings.
- Certificate expiration detection before threshold = 99.9 percent.
- Rotation policy evaluation success $\geq$ 99.9 percent.
- No plaintext secret persistence in AQELYN governance stores.

008 Definitions & Terminology

Secret: Sensitive authentication material such as an API key, password, token, or client secret.

Key: Cryptographic material used for encryption, signing, validation, or authentication.

Certificate: An X.509 certificate or equivalent credential binding identity information to public key material.

Trust Anchor: Root or intermediate certificate or equivalent authority used to establish trust.

Rotation: Controlled replacement of credential material according to policy or risk trigger.

Exposure: Evidence that credential material or unsafe metadata is present in an unauthorized location.

Fingerprint: A non-reversible representation used to correlate cryptographic material without storing plaintext.

Secret Lineage: Relationship between a credential, owner, application, provider, workload, and downstream consumers.

009 System Context

The engine operates between credential providers and AQELYN intelligence services. It consumes metadata from vaults, cloud platforms, CAs, CI/CD tools, code repositories, Kubernetes clusters, and scanning systems. It publishes governance findings to Event Bus, links evidence in Evidence Engine, updates Knowledge Graph relationships, consumes Trust and Policy context, and submits remediation requests to Workflow Engine.

Context flow:

External credential sources -> Discovery and Normalization -> Governance Repository -> Lifecycle Assessment -> Policy Evaluation -> Risk Scoring -> Recommendation -> Event Bus -> Knowledge Graph / Workflow / Compliance.

010 Architectural Overview

The architecture is modular and event-driven. Core subsystems include Discovery Manager, Normalization Service, Credential Repository, Lifecycle Engine, Exposure Detection Engine, Certificate Intelligence Module, Key Governance Module, Policy Adapter, Trust Adapter, Risk Scoring Engine, Recommendation Engine, Event Publisher, and Reporting/Analytics.

Architectural properties:

- No plaintext secret storage.
- Provider-neutral canonical model.
- Deterministic rule evaluation.
- Versioned policy and scoring algorithms.
- Evidence-backed findings.
- Horizontal scalability.
- Pluggable connectors.
- Immutable lifecycle events.

011 Internal Architecture

Internal processing pipeline:

1. Connector receives provider metadata or event.
2. Normalization maps source object to canonical AQELYNCredentialAsset.
3. Repository records immutable asset version and lifecycle state.
4. Lifecycle Engine evaluates age, rotation, expiration, and status.
5. Policy Adapter evaluates policy obligations.
6. Trust Adapter enriches with trust context.
7. Risk Scoring Engine calculates risk and governance score.
8. Recommendation Engine generates remediation guidance.

9. Event Publisher emits signed lifecycle and governance events.

Services communicate using versioned internal contracts and correlation identifiers. Processing shall be idempotent where source events may be retried.

012 Component Specifications

Discovery Manager: orchestrates connectors, schedules scans, handles delta synchronization, and validates connector health.

Normalization Service: converts provider data to canonical asset models while preserving provider references.

Credential Repository: stores metadata, lifecycle state, evidence links, fingerprints, policies, ownership, and history.

Lifecycle Engine: evaluates creation, activation, use, rotation, suspension, revocation, expiration, destruction, and archival.

Exposure Detection Engine: correlates scanner results, repository findings, public exposure signals, and unsafe storage indicators.

Certificate Intelligence Module: evaluates X.509 metadata, SANs, issuer chain, expiration, revocation, ECU/KU, trust path, and renewal policy.

Key Governance Module: evaluates key type, algorithm, size, usage, rotation, location, HSM/KMS association, and authorization.

Recommendation Engine: maps findings to remediation actions and workflow requests.

Event Publisher: signs and publishes immutable governance events.

013 Universal Credential Asset Model

Canonical object: AQELYNCredentialAsset.

Attributes:

- AssetId
- AssetType
- ProviderId
- ProviderType
- Owner
- OwningIdentity
- Environment
- Sensitivity
- LifecycleState
- CreatedAt
- LastObservedAt
- LastRotatedAt
- ExpirationAt
- RotationPolicy
- StorageLocation
- UsageContext
- FingerprintReference
- TrustScore
- GovernanceScore
- RiskLevel

- EvidenceReferences
- PolicyReferences

Relationships:

- OwnedBy
- UsedBy
- Authenticates
- Signs
- Encrypts
- Protects
- StoredIn
- RotatedBy
- IssuedBy
- Trusts
- Exposes
- Replaces

014 Lifecycle Model

Credential lifecycle states:

Requested -> Approved -> Created -> Distributed -> Active -> Monitored -> RotationPending -> Rotated -> Deprecated -> Suspended -> Revoked -> Destroyed -> Archived.

Certificate lifecycle states:

Requested -> Validated -> Issued -> Deployed -> Active -> RenewalPending -> Renewed -> Expiring -> Expired -> Revoked -> Archived.

Key lifecycle states:

Generated -> Enabled -> Active -> RotationPending -> Disabled -> Destroyed -> Archived.

Every transition generates an immutable lifecycle event and updates the governance history.

015 Governance Model

Governance domains:

1. Ownership - owner, owning system, accountable team.
2. Storage - approved vault/KMS/HSM, unsafe storage indicators.
3. Rotation - age, schedule, failures, emergency rotation triggers.
4. Strength - algorithm, length, protocol, entropy indicators where available.
5. Usage - scope, consumers, last use, environment, mission linkage.
6. Exposure - leaked, embedded, logged, committed, or externally detected.
7. Compliance - policy, regulatory, internal standard alignment.
8. Trust - trust score of owner, issuer, storage platform, and consumers.

Governance scores are deterministic and policy-version-aware. Findings shall never require storage of plaintext secrets.

016 Trust Model

Trust enrichment uses AQELYN Trust Engine outputs for owner identity, machine identity, provider, certificate issuer, storage system, consuming workload, and evidence confidence. Trust impacts prioritization but shall not suppress mandatory policy violations.

Trust inputs:

- Identity confidence
- Provider integrity
- Historical reliability
- Evidence confidence
- Behavioral consistency
- Storage platform assurance
- Issuer confidence

017 Policy Model

Policy categories:

- Rotation policy
- Storage policy
- Certificate expiration policy
- Key strength policy
- Secret exposure policy
- Ownership policy
- Environment separation policy
- Signing key policy
- Trust anchor policy
- Emergency revocation policy

Policy evaluation result fields: PolicyId, Version, Result, Severity, Evidence, EvaluationTime, RuleTrace, RemediationHint.

018 Event Model

Core events:

- CredentialAssetDiscovered
- CredentialAssetUpdated
- SecretExposureDetected
- CredentialRotationRequired
- CredentialRotationCompleted
- CertificateExpiring
- CertificateExpired
- CertificateRevoked
- WeakKeyDetected
- UnauthorizedSecretStorageDetected
- CredentialOwnerMissing

- CredentialGovernanceAssessmentCompleted
- CredentialRiskScoreChanged
- CredentialRemediationRecommended

Event envelope includes EventId, EventType, Version, Timestamp, CorrelationId, SourceEngine, AssetId, Severity, EvidenceReferences, PolicyReferences, TrustContext, MissionContext, Signature.

019 Internal Interface Contracts

DiscoveryService.DiscoverAssets(source, scope)
NormalizationService.Normalize(sourceRecord)
RepositoryService.UpsertCredentialAsset(asset)
LifecycleService.EvaluateLifecycle(assetId)
PolicyService.EvaluateCredentialPolicies(assetId)
TrustService.GetCredentialTrustContext(assetId)
RiskService.CalculateCredentialRisk(assetId)
RecommendationService.GenerateCredentialRecommendations(assetId)
EventPublisher.PublishCredentialEvent(event)

All interfaces shall be versioned, backward-compatible where possible, observable, authenticated, and authorized.

020 External Interface Contracts

External connectors shall support least-privilege access and avoid retrieving plaintext secret values unless absolutely required by a safe provider-specific metadata operation. Default mode is metadata-only.

Connector categories:

- Vault and secrets managers
- Cloud KMS and secret platforms
- Certificate authorities and certificate inventory systems
- Kubernetes secrets and workload identity platforms
- CI/CD and DevOps platforms
- Code scanning and secret exposure scanners
- HSM/KMS metadata platforms
- API management platforms

021 Security Architecture

Security objectives:

- Never persist plaintext secrets.
- Protect sensitive metadata.
- Verify event integrity.
- Enforce connector least privilege.
- Validate all input from external providers.
- Use platform cryptographic services only.
- Maintain tamper-evident audit history.

Trust boundaries include external providers, connector runtime, AQELYN processing, repository storage, event bus, administrative interfaces, and workflow automation boundaries.

022 Threat Model

Threats:

- Secret theft or leakage
- Unauthorized secret retrieval
- Weak cryptographic material
- Expired certificates causing outages
- Forged or untrusted certificates
- Signing key compromise
- Rogue trust anchor
- Secret reuse across environments
- Hard-coded credentials in repositories
- Malicious connector behavior
- Governance event tampering

Mitigations include metadata-only design, exposure detection, rotation policy, certificate intelligence, trust anchor governance, signed events, connector attestation, least privilege, evidence correlation, and workflow-based remediation.

023 Cryptographic Architecture

The engine uses AQELYN cryptographic services for hashing, digital signatures, certificate validation, random identifiers, integrity metadata, and manifest generation. It shall not implement custom cryptography.

Sensitive correlations use safe fingerprints and references. Where fingerprints could become sensitive, access controls and hashing strategies shall be governed by policy.

Event signatures and manifest hashes support audit verification.

024 Performance Architecture

Targets:

- Credential assets: ≥ 100 million metadata records.
- Governance evaluations: ≥ 250 million/day.
- Certificate expiration evaluations: near-real-time for configured thresholds.
- Event publication latency: ≤ 250 ms under nominal load.
- Repository query latency: ≤ 250 ms P95 for indexed asset lookups.

Processing supports parallel evaluation, incremental synchronization, provider backoff, queue partitioning, and workload sharding by provider, environment, and asset type.

025 Scalability Architecture

Scalability dimensions:

- Provider connector count

- Asset inventory size
- Event throughput
- Policy evaluation volume
- Historical retention
- Analytics workload

Mechanisms:

- Stateless workers
- Partitioned repositories
- Distributed queues
- Read replicas
- Connector worker pools
- Incremental scans
- Cache of policy versions
- Backpressure support

026 Reliability & High Availability

Availability target: 99.9 percent or greater.

Failure scenarios: provider outage, connector failure, event bus interruption, repository degradation, policy timeout, trust engine outage, scanner feed delay.

Recovery: retry with exponential backoff, circuit breakers, idempotent writes, event replay, queue persistence, degraded mode evaluation, health checks, and operator alerts.

027 Observability Architecture

Observability covers discovery, normalization, lifecycle evaluation, policy evaluation, trust enrichment, risk scoring, recommendation generation, and event publication.

Metrics include asset count, unknown owners, expiring certificates, rotation failures, exposure findings, weak keys, high-risk assets, evaluation latency, connector health, and event failures.

Traces propagate correlation identifiers from provider event to published AQELYN event.

028 Logging Architecture

Structured logs include timestamp, correlation ID, asset ID, provider, operation, component, severity, outcome, duration, policy references, evidence references, and error classification.

Logs shall not include plaintext secrets, private keys, bearer tokens, or full credential values. Redaction rules are mandatory and tested.

029 Monitoring & Operational Metrics

Dashboards:

- Credential inventory coverage
- Rotation compliance

- Certificate expiration horizon
- Exposure findings
- Weak cryptography findings
- Provider connector health
- Policy violation trends
- Remediation backlog
- High mission impact credentials

Alerts:

- Critical exposure detected
- Certificate expires within emergency threshold
- Rotation failure on high-risk credential
- Unknown owner for critical credential
- Connector integrity failure

030 Engineering Constraints

Constraints:

- Repository structure is immutable.
- Master Markdown is source of truth.
- No plaintext secret persistence.
- Provider-specific logic stays in connectors.
- Core governance logic remains provider-neutral.
- All findings require evidence references.
- All events use Universal Event Model.
- Policy and rule versions are required for deterministic replay.

031 Testing Strategy

Unit tests: normalization, lifecycle state transitions, scoring rules, policy evaluation, redaction utilities.

Integration tests: Vault, cloud secrets, KMS, Kubernetes, PKI, CI/CD, Event Bus, Evidence, Policy, Trust, Workflow.

System tests: discovery-to-remediation lifecycle, certificate expiration workflow, secret exposure workflow, weak key detection, owner remediation.

Performance tests: high-volume metadata ingestion, policy evaluation, event publication, repository queries.

Security tests: redaction, authorization, connector least privilege, event signature validation, no plaintext persistence, audit completeness.

Resilience tests: provider outages, scan feed delay, event bus interruption, trust/policy degradation, repository failover.

032 Validation & Acceptance Criteria

Functional acceptance:

- Assets discoverable from configured sources.
- Canonical models validated.
- Lifecycle states computed correctly.
- Certificate expiration and revocation findings generated.

- Secret exposure findings linked to evidence.
- Rotation recommendations generated.
- Events published and signed.
- Workflow requests submitted where configured.

Non-functional acceptance:

- Evidence linkage 100 percent for findings.
- No plaintext secrets in generated logs or repositories.
- Deterministic score replay for identical inputs.
- Availability and performance targets demonstrated under test.

033 Requirements Matrix

REQ-FR-035-001 Discover credential assets | Mandatory | Integration Test
REQ-FR-035-002 Normalize asset metadata | Mandatory | Unit Test
REQ-FR-035-003 Maintain lifecycle state | Mandatory | System Test
REQ-FR-035-004 Evaluate rotation policy | Mandatory | Functional Test
REQ-FR-035-005 Detect certificate expiration | Mandatory | Functional Test
REQ-FR-035-006 Detect weak keys | Mandatory | Functional Test
REQ-FR-035-007 Detect exposure indicators | Mandatory | Integration Test
REQ-FR-035-008 Link evidence to findings | Mandatory | Integration Test
REQ-FR-035-009 Publish governance events | Mandatory | Integration Test
REQ-FR-035-010 Generate remediation recommendations | Mandatory | Functional Test
REQ-NFR-035-001 No plaintext persistence | Mandatory | Security Test
REQ-NFR-035-002 Deterministic evaluation | Mandatory | Repeatability Test
REQ-NFR-035-003 Horizontal scalability | Mandatory | Performance Test
REQ-NFR-035-004 High availability | Mandatory | Resilience Test
REQ-NFR-035-005 Observability | Mandatory | Operational Test

034 Traceability Matrix

REQ-FR-035-001 -> Discovery Manager -> connector integration tests -> discovery reports
REQ-FR-035-002 -> Normalization Service -> mapping unit tests -> mapping validation
REQ-FR-035-003 -> Lifecycle Engine -> system lifecycle tests -> lifecycle logs
REQ-FR-035-004 -> Policy Adapter -> functional policy tests -> rotation evaluation report
REQ-FR-035-005 -> Certificate Intelligence Module -> functional certificate tests -> certificate alert evidence
REQ-FR-035-006 -> Key Governance Module -> weak key tests -> cryptographic hygiene report
REQ-FR-035-007 -> Exposure Detection Engine -> scanner integration tests -> exposure evidence package
REQ-FR-035-008 -> Evidence Integration -> evidence integration tests -> evidence reference set
REQ-FR-035-009 -> Event Publisher -> event bus tests -> event publication log
REQ-FR-035-010 -> Recommendation Engine -> recommendation tests -> remediation report
REQ-NFR-035-001 -> Security Architecture -> data leakage tests -> no-plaintext evidence
REQ-NFR-035-002 -> Scoring Engine -> repeatability tests -> determinism report

REQ-NFR-035-003 -> Scalability Architecture -> load tests -> benchmark report

REQ-NFR-035-004 -> Reliability Architecture -> failover tests -> resilience report

REQ-NFR-035-005 -> Observability Architecture -> telemetry tests -> dashboard evidence

035 Engineering Journal

Major decisions:

- AQELYN shall govern credential metadata and lifecycle without becoming a plaintext secret store.
- Provider-specific behavior is isolated in connectors.
- Findings must be evidence-backed.
- Credential assets are first-class graph nodes linked to identities, workloads, providers, policies, and missions.
- Certificate governance is included because certificate failure is both a security and availability risk.

Assumptions:

- External systems remain authoritative for storing secrets and issuing certificates.
- Connectors can obtain safe metadata under least-privilege configurations.
- Some providers may expose incomplete metadata; confidence scores and evidence quality must reflect this.

Future work:

- Confidential computing attestation integration.
- Post-quantum cryptography lifecycle policy.
- Automated emergency credential revocation playbooks.
- Expanded signing key provenance tracking.

036 Example Artifacts

Example artifact set:

1. Credential Inventory Report
2. Certificate Expiration Report
3. Secret Exposure Finding
4. Rotation Recommendation
5. Weak Key Finding
6. Trust Anchor Governance Report
7. Credential Ownership Compliance Report
8. Remediation Workflow Request
9. Event Publication Sample
10. Evidence Reference Package

Example event snippet:

EventType: CertificateExpiring

AssetType: X509Certificate

Severity: High

ThresholdDays: 14

Evidence: certificate_metadata_snapshot, provider_observation, policy_evaluation

Recommendation: renew_certificate_before_threshold

037 Publication Manifest

Required publication contents:

- EA-0035_Master.md
- EA-0035.pdf
- EA-0035.html
- README.md
- manifest.json
- matrices/Requirements_Matrix.csv
- matrices/Traceability_Matrix.csv
- journal/Engineering_Journal.md
- examples/example_artifacts.json
- diagrams/Architecture.svg
- diagrams/Component.svg
- diagrams/Workflow.svg
- diagrams/EventFlow.svg
- diagrams/Integration.svg
- EA-0035_FULL_COMPLETE.zip

038 References

Normative references:

- AQELYN Project Charter
- Engineering Principles
- Repository Standard
- Architecture Guide
- Development Rules
- Publication Standard
- IS-001 through IS-035
- EA-0001 through EA-0034

Informative references:

- NIST SP 800-57 key management concepts
- NIST SP 800-53 security controls
- NIST SP 800-207 Zero Trust Architecture
- OWASP secrets management guidance
- CNCF workload identity concepts
- X.509 and PKI operational concepts

039 Engineering Review

Completeness review:

- Vision, purpose, scope, objectives complete.
- Architecture and component specifications complete.
- Canonical object model complete.
- Lifecycle, governance, trust, policy, and event models complete.
- Security, threat, cryptographic, performance, scalability, reliability, observability, logging, and monitoring sections complete.
- Requirements and traceability matrices complete.
- Engineering journal and example artifacts complete.

Standards review:

- Repository unchanged.
- Engineering sequence maintained.
- Master Markdown is source of truth.
- FULL_COMPLETE publication artifacts defined.

040 Publication Readiness

EA-0035 is publication-ready when all derived artifacts are generated from the approved Master Markdown and packaged with manifest hashes. Publication shall include complete Markdown, PDF, HTML, README, manifest, matrices, journal, examples, five SVG diagrams, and final ZIP package.

Engineering status: approved for FULL_COMPLETE publication.